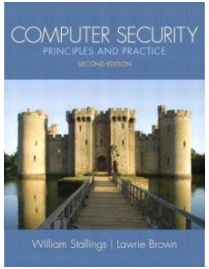
אבטחת מידע

(אבטחת סייבר/מחשבים/מערכות ממוחשבות/...)

האוניברסיטה הפתוחה

מנחה ומרכז: איציק בייז



המצגת הינה לשימוש פנימי בלבד

אין לצלם או לעשות שימוש שלא במסגרת הקורס

נושאי השיעור

- אדמיניסטרציה
- נושאי הקורס
- אבטחה – נושאים ומושגים בסיסיים

אדמיניסטרציה

- ספר הקורס:
  - Computer Security, Stallings, 4th ed.
- קשר איתי:
  - בטלפון: בתיאום
  - כתובת דוא"ל: itzikba@openu.ac.il
- מפגשים:
  - סקירה כללית, תרגול

אדמיניסטרציה

- אתר הקורס: מצגות, מטלות, הודעות, וכדומה.
- דרישות הקורס:
  - 5 מטלות תיאורטיות, 1 תכנותי, מבחן (75%)
- הגשת מטלות:
  - ביחידים
  - הגשת המטלות באתר
  - בודק התרגילים: TBD

נושאי הקורס

- סכנות ושיטות הגנה
- מודלים ומדיניות
- הצפנה ופרוטוקולים
- אימות זיהוי
- בקרת גישה
- הגנה בחומרה ובמערכות הפעלה
- הגנה בבסיסי נתונים
- וירוסים, תולעים, ודומיהם
- תכנות בטוח
- הגנה ברשתות תקשורת וב-WWW
- ועוד, ככל שירשה לנו הזמן

אבטחה – נושאים ומושגים בסיסיים

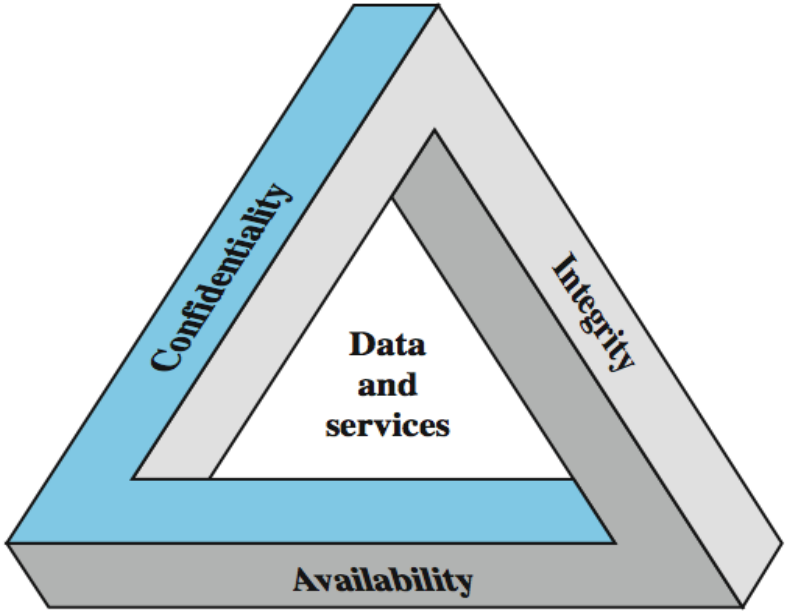
- CIA
  - Confidentiality, Integrity, Availability (סודיות, שלמות, זמינות)
- Authenticity, Accountability (אותנטיות, עקרון האחריות)
- Non-repudiation (אי הכחשה)
- Privacy, Trust, etc. (פרטיות, אמון)
- Wide topic
- Show conference call for papers
  - e.g. https://attend.ieee.org/dsc-2022/

אבטחה – נושאים ומושגים בסיסיים

- סקירת אתרי סייבר מאת יגאל אונא, ראש מערך הסייבר הישראלי

https://www.youtube.com/watch?v=zS0rXsyXcC4

Key Security Concepts



Question

Classify to confidentiality, integrity, availability:

- Web site defacing (השחתה)
- Changing the amount on a check
- Forging a signature
- Shoulder surfing

Computer Security Challenges

1. not simple
2. must consider potential attacks
3. procedures used counter-intuitive
4. involve algorithms and secret info
5. must decide where to deploy mechanisms
6. battle of wits between attacker / admin
7. not perceived on benefit until fails
8. requires regular monitoring
9. too often an after-thought
10. regarded as impediment (מגבלה) to using the system

Some common terms

- Vulnerability (חולשה/פגיעות)
- Threat
- Threat vs. Vulnerability (or Being Vulnerable to the Threat of Confusing Threats with Vulnerabilities)
  - Threat: Adversaries might **install malware** in the computers in our Personnel Department so they can **steal** social security numbers for purposes of **identity theft**
  - Vulnerability: The computers in the Personnel Department do not have up to date virus definitions for their anti-malware software

Some common terms

- Attack: An attempt by an adversary to cause harm to valuable assets
- Attack vector: a path or means of an adversary to enable them to exploit system vulnerabilities (including the human element).
  - e.g. viruses, e-mail attachments, deception, …
- Threat model – usually means what threats or attacks we protect against

Vulnerabilities and Attacks

- **system resource with vulnerabilities may**
  - be corrupted (loss of integrity)
  - become leaky (loss of confidentiality)
  - become unavailable (loss of availability)
- **attacks are threats carried out and may be**
  - passive
  - active
  - insider
  - outsider

Attackers

Insiders–

According to studies, about half of the attacks to a system come from insiders [Neu99]. Threats include: intellectual property (IP) theft, IT sabotage, fraud, espionage, and accidental insider threats

Hacker – (Wikipedia)

"someone who seeks and exploits weaknesses in a computer system or computer network. Hackers may be motivated by a multitude of reasons, such as profit, protest, or challenge."

Warfare / Espionage / etc.–
Industrial or government espionage/sabotage/etc.

Methods of Attacks

Bypassing authentication
(e.g. guessing password)

Using Authority dishonestly
(e.g. System people)

Utilizing human error or carelessness

Utilizing “holes” in Software

Bypassing access control

Using Viruses

Use Inference from authorized access

Defense vs. Offense

- Attackers need to succeed only once
- Defenders must succeed every time!

BUT

- Attackers must pass through a chain of defenses
- Defenders only need to succeed in one link!

Common targets

Ideas?

https://www.youtube.com/watch?v=GqW_Xwgwvds

https://vimeo.com/63176830

Avi Rubin's Ted Talk

Major threats

- Stolen passwords
- Malware\Spyware
- Phishing
- Social Engineering
- DDOS
- Rogue SSL certificates
- Web exploiting (SQL injection, XSS,…)
- Android

Notable incidents & vulnarbilities

Partial list from recent years:

Sony, HBGary, Lockheed Martin, RSA, “Goto fail”, Heartbleed, Meltdown & Spectre…

Cyber warfare:

Estonia and Georgia, Stuxnet, Flame, … (Ongoing)

נושאים נוספים

- גונבה
- רגולציה
- בנק ישראל, המטה הקיברנטי הלאומי,...
- המדינה נגד אבי מזרחי
- דואר זבל
- פישינג

מן העתונות – גניבת זהות

לאומי מזהיר: ניסיונות לביצוע הונאת "פישינג" נגד לקוחות הבנק

17:44 ,09.02.13

הבנק הודיע כי בימים האחרונים נעשו כמה ניסיונות לביצוע ההונאה - במסגרתה מתבקשים הלקוחות להיכנס לאתר המתחזה לאתר הרשמי של הבנק ולמסור את פרטיהם. "אנו חוסמים את חשבונותיהם של לקוחות אשר בלא יודעין נכנסים לאתרים המתחזים"

לקוחות בנק לאומי באינטרנט מאוימים בימים האחרונים על ידי הונאת "פישינג". במסגרת זו, הלקוחות מקבלים הודעת מייל בה הם מתבקשים להיכנס לאתר המתחזה לאתר הרשמי של הבנק - ולמסור את פרטיהם, שנחשפים למעשה בפני הגורמים האחראים להונאה.

כך למשל, ביום חמישי זיהו אנשי אבטחת המידע של הבנק אתר אינטרנט שהתחזה לאתר לאומי. בלאומי מסבירים שהזיהוי נעשה ברגע עלייתו לאוויר, ומרגע זה נוטר האתר המתחזה, כשהלקוחות הספורים אשר נכנסו אליו בלא יודעין, והזינו את שם המשתמש שלו וסיסמתו, נחסמו מיידית לגלישה. כעבור זמן קצר הורד האתר המתחזה מהרשת, והאירוע הסתיים.

בתגובה, פרסם הבנק אזהרה בדף הפייסבוק שלו: "בימים האחרונים אנו עדים לניסיונות חוזרים ונשנים לבצע הונאת 'פישינג' על לקוחות לאומי ולקוחות של חברות אחרות בארץ ובעולם", נכתב.

"אנשי אבטחת המידע של לאומי עוקבים
ומנטרים את כל הניסיונות הללו וחוסמים בזמן
אמת את חשבונותיהם של לקוחות אשר בלא יודעין נכנסים לאתרים המתחזים ומוסרים
את פרטיהם. אנו חוזרים ומודיעים: לאומי אינו נוהג לשלוח ללקוחותיו הודעות דואר
אלקטרוני המבקשות מהלקוח להיכנס לאתר האינטרנט של הבנק ולמסור את פרטי
ההזדהות שלו. אם קיבלתם הודעה שכזו, אנא מחקו אותה באופן מיידי", הזהירו בבנק.

http://www.calcalist.co.il/local/articles/1,7340,L-3595090,00.html

עוד מן העתונות

גוגל מזהירה: התגלה ליקוי אבי
חמור בדפדפן כרום

הבאג מאפשר להאקרים לחדור למחשב ש
ולפי הערכות היה קיים בכרום מאז
בזריזות את הדפדפן בגרסא

רפאל קאהאן 07.03.19

חוקרים ישראלים חשפו פירצת אבטחה
במסנג'ר של פייסבוק

09:49 | 10.03.2019

חוקרים ישראלים מחברת אבטחת המידע אימפרבה (Imperva) חשפו פירצת אבטחה במסנג'ר של פייסבוק שאיפשרה לתוקפים פוטנציאלים לעקוב אחר הפעילות שלכם ועם מי שוחחתם

... אל עדיין עובדות
...יהן

...ראו עד כמה קל לפרוץ ולגנוב מידע רפואי רגיש
... המרכזיים בארץ

שגיא כהן
07.03.2019

30 10 שמור

ועוד מן העתונות

Microsoft patches Windows 10 after the NSA quietly told it about a major vulnerability

TUE, JAN 14 2020

https://www.cnbc.com/2020/01/14/microsoft-to-patch-windows-10-after-nsa-finds-vulnerability.html

אלפי עסקים קטנים בישראל סובלים ממתקפות סייבר

https://www.ynet.co.il/articles/0,7340,L-5629138,00.html

נשיא לשכת ארגוני העצמאים והעסקים בישראל הגיע למרכז הסייבר כדי לדון בסיוע לעסקים שניזוקים תדיר מהתופעה. לדבריו, עסקים אלה הפכו ליעד מרכזי לפריצות בגלל חוסר ההיערכות שלהם והסיכוי שיעדיפו לשלם כופר בתמורה לחומרים: "מרבית אירועי הסייבר לא מדווחים בגלל שהעסקים מפחדים שהמוניטין שלהם יפגע"

20. 11. 19

Defending Against COVID-19 Cyber Scams

Published: Friday, March 6, 2020

The Cybersecurity and Infrastructure Security Agency (CISA) warns individuals to remain vigilant for scams related to Coronavirus Disease 2019 (COVID-19). Cyber actors may send emails with malicious attachments or links to fraudulent websites to trick victims into revealing sensitive information or donating to fraudulent charities or causes. Exercise caution in handling any email with a COVID-19-related subject line, attachment, or hyperlink, and be wary of social media pleas, texts, or calls related to COVID-19.

(https://www.us-cert.gov/ncas/current-activity)

חדש מן העתונות

"תקלה קריטית": אירוע סייבר בביה"ח הלל יפה

מערכות המחשוב בבית החולים נפגעו, וכעת המוסד מתנהל במערכות חלופיות • הטיפול הרפואי מתקיים באופן שוטף למעט פעילות אלקטיבית לא דחופה • בבית החולים מגדירים את התקלה כתקלה קריטית ומבקשים מהצוות הרפואי "לעבוד באופן ידני ולפי סדרי עדיפויות"

נבו טרבלסי | פורסם: 13.10.2021 | עודכן: 17.10.2021

איראן חושפת: היקף הפגיעה העצום של מתקפת הסייבר על תחנות הדלק

באיראן פורסם הנזק הגדול שנגרם לאלפי תחנות דלק ברחבי המדינה. זאת, כיממה לאחר שהודיעו על שיבושים נרחבים, שנגרמו כתוצאה ממתקפת סייבר שמקורה תחת חקירה

רויטרס 27/10/2021 10:15 | 1 דק' קריאה | השמעה

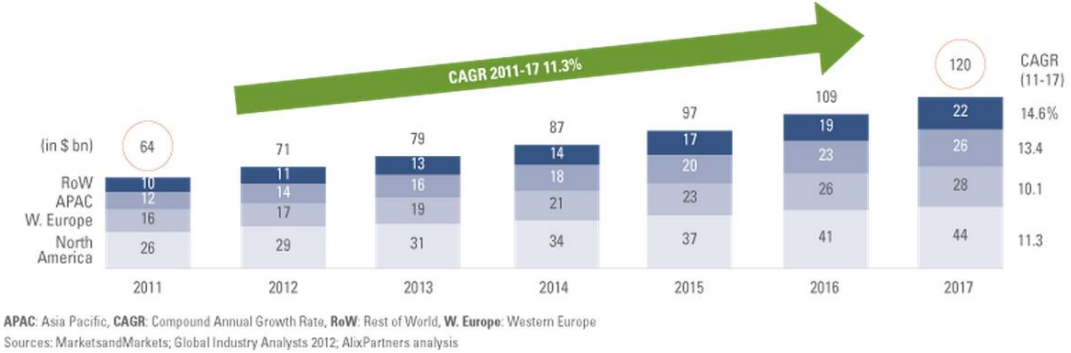
Lo and Bhold…

Part 6 – earthly invaders

(http://www.documentarymania.com/player.php?title=Lo%20and%20Behold%20Reveries%20of%20the%20Connected%20World , ~50:00)

Computer Security Economy

Cyber-Security market share 155.74 B$ by 2019.



אקזיט: סימנטק רכשה את לומינייט הישראלית בכרבע מיליארד דולר

הטכנולוגיה של הנרכשת מאפשרת לארגונים לספק גישה מאובטחת ומצומצמת אך ורק ליישומים ומשאבים אליהם המשתמש מורשה לגשת, ולעשות זאת מכל תחנת קצה בכל מקום בעולם

מאת יניב הלפרין 12 בפברואר 2019, 18:05 א+ / א- הדפסה

CSIS Study Pegs Median Global Cyber-Crime Cost at $445 Billion

http://csis.org/event/2014-mcafee-report-global-cost-cybercrime

Countermeasures

Means used to deals with security attacks

- prevent
- detect
- recover

Goal: minimize risk to an asset

May introduce new vulnerabilities

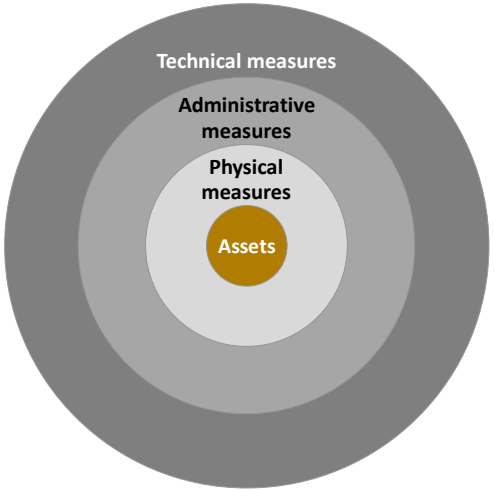
Residual vulnerability (incomplete solution)

Types of security controls and solutions

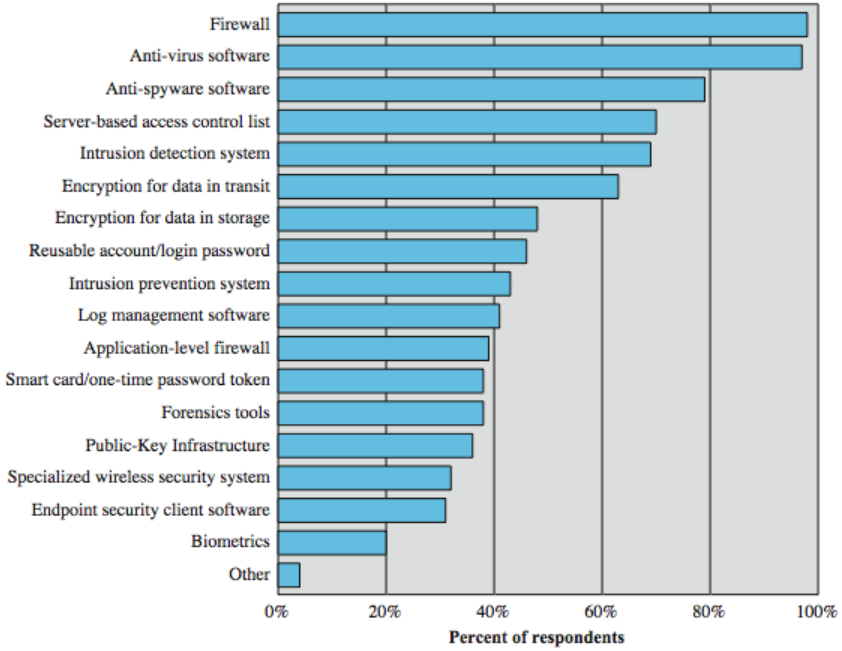
Physical measures: CCTV, guard, fences, locks, CD-ROM\USB removal, fire alarms, controlling individual access to the facility…

Administrative measures: developing and publishing policies, standards, procedures and guidelines, screening and background checks, awareness, risk assessment, audit, training…

Technical (logical) measures: access control mechanisms to systems, passwords, firewalls, anti-virus, IDS, VPNs, configuration managements, backup…



Security Technologies Used



Source: Computer Security Institute/FBI 2006 Computer Crime and Security Survey

Computer security strategy – how do we get it done?

Specification/policy

- what is the security scheme supposed to do?
- consider the value of the assets; vulnerabilities; potential threats and the likelihood of attacks
- Trade-off 1: "Ease of use versus security"
- Trade-off 2: "Cost of security versus cost of failure and recovery"

Risk management

Implementation/mechanisms

- how does it protect the asset?
- prevention, detection, response, recovery

Correctness/assurance

- does it really work?
- assurance, evaluation

Typical Risk Analysis Form

DESCRIPTION OF RISK	POTENTIAL EFFECT	POTENTIAL COST OF RISK	PROBABILITY (high=.75) (average=.50) (low=.25) (negligible=.05)	COST PROBABILITY PRODUCT ($x10^3$) (RELATIVE PRIORITY) (high priority is highest product	PREVENTATIVE / REMEDIAL ACTION	COSTS OF SAFEGUARD AND COMMENTS
1. Computer Room Destroyed	i. Loss of processing capability for production scheduling, payroll, etc. ii. Replacement of computer iii. Site reconstruction	$ 500,000 200,000 2,000,000	Low	675	i. Ensure adequate backup ii. Maintain fall-back manual system iii. Insure site and Equipment iv. Impose fire Precautions	Nil. $3,000 per year
2. Complete loss of Records	i. Unable to bill customers ii. Production line stoppage within four days iii. Unable to continue trading within six weeks	500,000 250,000 25,000,000	Low	6437.5	i. Ensure remote copies kept of all vital files ii. Insure against consequential loss during Recovery	$1,000 per year
3. Theft of information of use to Competitors	i. Erosion of market position ii. Estimated saving to Competitors	1,000,000 10,000	Average	505	i. Strict control of access to vital files ii. Personnel bonding	i. Impose system for signing out files
4. Illegal sale of machine Time	i. Slightly increased machine costs ii. Possible adverse effect on own systems testing	10,000 5,000	Negligible	0.750	i. Spot checks	No action recommended; risk/small loss outweighed by staff morale considerations
5. Improper Disclosure of personal Data	i. Lawsuit against firm ii. Loss of goodwill through publicity	10,000,000 7,500,000	High	13125	i. Tighten up controls at areas where information is disseminated ii. Put a legal notice on all forms with personal data specifying laws and sanctions applicable to it	Intangible effect and cost to data subjects important but not considered here

Who is responsible for security

Executive management\CEO ?

IT department\CTO ?

IT security stuff ?

Everyone! – all employees and stakeholders of the organization

Role of security in today's world

- Top management
  - Endorse and lead information security
- Chief Information Security Officer (CISO)
  - Responsible for the design and implementation of a comprehensive security plan
  - Risk management
  - Updated with the most recent threats and solutions.
- Information security implementer
  - Implement, install, support , maintain security tools
  - The "hands-on" function
  - Sometime the network administrator is also the IS implementer
  - Deep understanding in Windows, Linux, databases, network security and also in specific products (Symantec, Cisco …)

Role of security in today's world

Information security architect\engineer

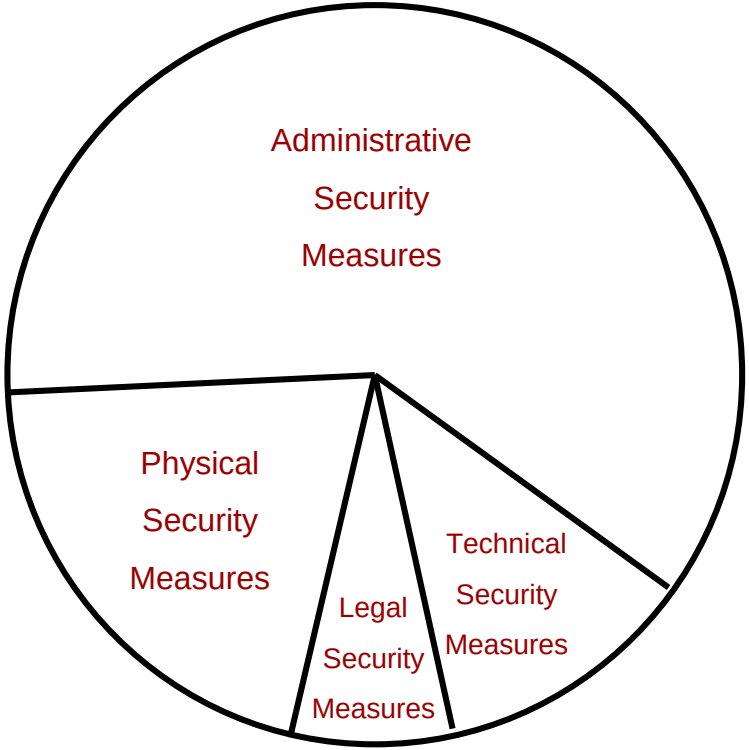
- Design the security solution that should protect the organization against its risks
- Instruct the IS implementers

Information security auditor

- Auditing of security products, processes, policies etc.

- Penetration tester\Ethical Hacker
  - Hacking to systems and assets
  - Detecting vulnerabilities
- Forensics investigator

Security Measures



Designing a security system

What goals do we want to achieve?

Does the system focus on the data, operations or the users of the system?

What level should the security system operate from? Should it be at the level of hardware, operating system or applications package?

Should it be simple or sophisticated?

In a distributed system, should the security be centralized or spread?

How do you secure the levels below the level of the security system?

Mitigating Insider Threats (CERT guidelines)

- 1. Consider threats from insiders and business partners in enterprise-wide risk assessments.
- 2. Clearly document and consistently enforce policies and controls.
- 3. Incorporate insider threat awareness into periodic security training for all employees.
- 4. Beginning with the hiring process, monitor and respond to suspicious or disruptive behavior.
- 5. Anticipate and manage negative issues in the work environment.
- 6. Know your assets.
- 7. Implement strict password and account management policies and practices.
- 8. Enforce separation of duties and least privilege.
- 9. Define explicit security agreements for any cloud services, especially access restrictions and monitoring capabilities.
- 10. Institute stringent access controls and monitoring policies on privileged users.
- 11. Institutionalize system change controls.
- 12. Use a log correlation engine or security information and event management (SIEM) system to log, monitor, and audit employee actions.
- 13. Monitor and control remote access from all end points, including mobile devices.
- 14. Develop a comprehensive employee termination procedure.
- 15. Implement secure backup and recovery processes.
- 16. Develop a formalized insider threat program.
- 17. Establish a baseline of normal network device behavior.
- 18. Be especially vigilant regarding social media.
- 19. Close the doors to unauthorized data exfiltration.

Information security
An on going process

Prevention

Monitoring and detection

Response

Emergency – carry out BCP

Recovery

Forensics \ investigation

Updating

Auditing,
Periodic testing